

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) → Stage 3 (Auto-Remediation) · Generated 2026-07-10 · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality`

Ranked remediation backlog — before/after status

#	Coordinate	Ver (before)	Band	Risk	Top CVE / issue	Fix	Status after PR
1	com.fastxml.jackson.core:jackson-databind	2.9.8	CRITICAL	2.8*	Typosquat (supply-chain)	remove	CLEARED — removed
2	org.apache.logging.log4j:log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1	CLEARED (top CVE); 5 lower-severity 2026-dated CVEs need verification
3	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1	CLEARED (top CVE); same caveat as log4j-core
4	com.fasterxml.jackson.core:jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8)	2.9.10.8	CLEARED — all 56 known CVEs
5	mysql:mysql-connector-java	8.0.30	HIGH	7.2	CVE-2023-22102 (8.3) + GPL-2.0 violation	8.2.0 of com.mysql:mysql-connector-j (rename)	MAJOR_REVIEW — untouched; rename fixes CVE but not the license
6	com.google.protobuf:protobuf-java (transitive)	3.19.4	HIGH	7.0	CVE-2022-3509 (7.5)	3.25.5 (or override)	MAJOR_REVIEW — tied to #5, untouched
7	com.google.guava:guava	24.1.1-jre	MEDIUM	5.5	CVE-2023-2976 (5.5)	32.0.0-jre	CLEARED
8	commons-io:commons-io	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.14.0	CLEARED
9	org.apache.commons:commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0	CLEARED
10	com.fasterxml.jackson.core:jackson-core (transitive)	2.9.8	LOW	2.2	none (outdated only)	2.9.10 (bundled)	CLEARED — bumped in lockstep with jackson-databind
11	com.fasterxml.jackson.core:jackson-annotations (transitive)	2.9.0	LOW	2.2	none (outdated)	2.9.10 (bundled)	CLEARED — bumped in lockstep

				only)			with jackson-databind
12	org.junit.jupiter:junit-jupiter	5.10.2	LOW	1.7	none (test-scope)	6.1.1	not in scope — no CVE, routine test-tooling bump only
13	com.google.code.findbugs:jsr305 (transitive)	1.3.9	LOW	1.7	none	n/a	superseded — guava 32.0.0-jre now pulls jsr305 3.0.2
14	org.checkerframework:checker-compat-qual (transitive)	2.0.0	LOW	1.7	license WARN	n/a	superseded — guava 32.0.0-jre pulls checker-qual:3.33.0 instead; WARN no longer applicable
15	com.google.errorprone:error_prone_annotations (transitive)	2.1.3	LOW	1.7	none	n/a	superseded — guava 32.0.0-jre now pulls 2.18.0
16	com.google.j2objc:j2objc-annotations (transitive)	1.1	LOW	1.7	none	n/a	superseded — guava 32.0.0-jre now pulls 2.8
17	org.codehaus.mojo:animal-sniffer-annotations (transitive)	1.14	LOW	1.7	none	n/a	no longer pulled in by guava 32.0.0-jre

* Row 1's formula-derived score (2.8) is overridden — supply-chain removal is prioritized above all CVE findings regardless of weighted score (see original rationale in `depscan-risk-report.json`).

Component scores (top items, before this PR)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0	7.8
log4j-api	10.0	8.0	2.0	7.8
jackson-databind	10.0	8.0	2.0	7.8
mysql-connector-java	8.8	8.0	2.0	7.2
protobuf-java (transitive)	9.5	6.0	2.0	7.0
guava	6.0	7.0	2.0	5.5

Priority recommendations — outcome

- P0** — Remove the typosquatted `com.fastxml.jackson.core` dependency (supply-chain). → **DONE**, removed.
- P0** — Upgrade log4j 2.14.1 → 2.17.1 (Log4Shell, actively exploited). → **DONE**; 5 newer CVE IDs with an ambiguous scanner-reported fix version flagged for follow-up verification.
- P1** — Upgrade jackson-databind 2.9.8 → a version that clears all 56 CVEs. → **DONE**, bumped to 2.9.10.8 (FasterXML's final 2.9.x consolidated patch).
- P1** — Upgrade guava → 32.0.0-jre (major review — API breakage possible). → **DONE**; `mvn test` package builds and tests clean, no source breakage (guava/commons/jackson unused directly in `DiscountCalculator.java`).
- P2** — Resolve mysql-connector GPL-2.0 license violation. → **NOT DONE** — routed to MAJOR_REVIEW follow-up; the available structural fix (rename to `com.mysql:mysql-connector-j`) clears the CVE but not the license family.
- P3** — Routine bumps: commons-io, commons-lang3. → **DONE** (2.14.0, 3.18.0).

Machine-readable source: `depscan-risk-report.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 2 ranking, Stage 3 remediation status.